



Full Maturity Assessment Facilitator Guide

A comprehensive guide for conducting Digital Sovereignty and Security maturity assessments

Version 1.0 - March 2026

Table of Contents

1. Introduction
2. Pre-Assessment Preparation
3. Facilitation Methodology
4. Domain Deep-Dives
5. Post-Assessment Activities
6. Facilitator Tips & Best Practices
7. Appendix

1. Introduction

Purpose of This Guide

This Facilitator Guide provides comprehensive instructions for conducting Full Maturity Assessments with customers and partners. It is designed to help you deliver consistent, high-quality assessments that provide valuable insights into an organization's Digital Sovereignty and Security maturity.

What is a Full Maturity Assessment?

The Full Maturity Assessment is a structured evaluation tool that measures an organization's capabilities across multiple domains using a proven 5-level maturity model based on the CMMI (Capability Maturity Model Integration) framework:

Level	Name	Range	Description
Level 1	Initial	0-20%	Unpredictable, reactive processes; ad-hoc approach
Level 2	Managed	21-40%	Planned and executed processes; basic controls in place
Level 3	Defined	41-60%	Standardized and documented processes across organization
Level 4	Quantitatively Managed	61-80%	Measured and controlled processes with metrics
Level 5	Optimizing	81-100%	Continuous improvement and innovation

Assessment Profiles

We offer two primary assessment profiles, each focused on different organizational priorities:

Digital Sovereignty

7 Domains: Data Sovereignty, Technical Sovereignty, Operational Sovereignty, Assurance Sovereignty, Open Source, Executive Oversight, Managed Services

Focus: Organizational control and independence from external dependencies, particularly important for government, healthcare, finance, and organizations with strict data residency requirements.

Security

7 Domains: Secure Infrastructure, Secure Data, Secure Identity, Secure Application, Secure Network, Secure Recovery, Secure Operations

Focus: Comprehensive security posture across all layers of the technology stack, ideal for compliance-driven organizations and those with high security requirements.

Tip

Most organizations benefit from starting with **Digital Sovereignty** as it addresses strategic independence concerns. Security assessments can follow to provide deeper technical security insights.

2. Pre-Assessment Preparation

Scheduling the Assessment

Proper preparation is critical to a successful assessment. Consider the following when scheduling:



Time Requirements

- **Full Assessment:** 2-4 hours depending on organization size and complexity
- **Quick Assessment:** 1-2 hours (covering only Foundation tier questions)
- **Follow-up Session:** 1 hour (for results review and roadmap planning)

Participant Selection

The assessment requires input from multiple stakeholders to ensure accurate ratings. Recommended participants:

Role	Why They're Needed	Essential?
CIO / CTO	Strategic oversight, budget authority, executive-level questions	Yes
CISO / Security Lead	Security controls, risk management, compliance frameworks	Yes
Cloud/Infrastructure Lead	Technical sovereignty, infrastructure control, vendor relationships	Yes
Compliance/Legal Officer	Data residency, jurisdictional control, regulatory requirements	Recommended
Operations Manager	Operational processes, disaster recovery, managed services	Recommended
Procurement Lead	Vendor management, supply chain, contract terms	Optional

Industry (LOB) Selection

Selecting the appropriate Line of Business (LOB) is crucial as it applies industry-specific weightings to domains. Guide your customer through this decision:

Finance

Best for: Banks, insurance companies, financial services, payment processors

Emphasized domains: Data Sovereignty (2.0×), Assurance Sovereignty (2.0×), Operational Sovereignty (1.5×)

Rationale: Financial institutions face stringent regulatory requirements (PCI DSS, SOX, DORA) demanding strong data protection, audit controls, and business continuity.

Healthcare

Best for: Hospitals, health systems, medical research, healthcare technology

Emphasized domains: Data Sovereignty (2.0×), Operational Sovereignty (2.0×)

Rationale: Healthcare organizations must protect sensitive patient data (HIPAA, GDPR) while maintaining 24/7 operational resilience for patient safety.

Government

Best for: Federal/state/local government, public sector, defense contractors

Emphasized domains: Data Sovereignty (2.0×), Assurance Sovereignty (2.0×), Executive Oversight (2.0×)

Rationale: Government entities handle sensitive citizen data and critical infrastructure with strict sovereignty requirements, transparency needs, and national security concerns.

Manufacturing

Best for: Industrial manufacturing, automotive, aerospace, discrete manufacturing

Emphasized domains: Operational Sovereignty (2.0×), Managed Services (2.0×)

Rationale: Manufacturers prioritize production uptime, OT/IT integration, and IP protection for proprietary designs and processes.

Telecommunications

Best for: Telecom providers, ISPs, mobile carriers, network infrastructure

Emphasized domains: Data Sovereignty (2.0×), Operational Sovereignty (2.0×), Assurance Sovereignty (2.0×)

Rationale: Telecom operators manage critical communications infrastructure with subscriber data protection requirements and strict regulatory compliance (NIS2).

Balanced / Other

Best for: Organizations without specific industry focus or those spanning multiple sectors

Emphasized domains: All domains equally weighted (1.0×)

Rationale: Provides an unbiased assessment across all domains without industry-specific emphasis.

Pre-Assessment Checklist

Send this checklist to participants at least 1 week before the assessment:



Pre-Assessment Information Needed

- Current cloud infrastructure provider(s) and services used
- List of critical business applications and their hosting locations
- Existing compliance frameworks and certifications (ISO 27001, SOC 2, etc.)
- Data classification policies and data residency requirements
- Key vendor relationships and managed service providers
- Recent security audits or risk assessments
- Disaster recovery and business continuity documentation
- Open source usage policies (if applicable)

3. Facilitation Methodology

Workshop Structure

A well-structured session keeps participants engaged and ensures comprehensive coverage of all domains.

- **0:00-0:15 - Introduction & Context Setting (15 min)**

Explain assessment purpose, maturity model, review agenda, confirm participants and roles

- **0:15-0:25 - Profile & Industry Selection (10 min)**

Discuss and select appropriate assessment profile and industry weighting

- **0:25-2:25 - Domain Assessment (120 min)**

Work through each domain systematically (~17 min per domain for 7 domains)

- **2:25-2:45 - Results Review (20 min)**

Review spider chart, discuss scores, identify obvious gaps

- **2:45-3:00 - Next Steps & Wrap-up (15 min)**

Discuss next steps, schedule follow-up, export results

Time Management

Sessions often run long as participants want to discuss their challenges. Build in buffer time or be prepared to schedule a continuation session. Consider breaking complex assessments into multiple shorter sessions.

Opening Script

Use this script to open your assessment session professionally:

Sample Opening

"Thank you all for joining today's Full Maturity Assessment. Over the next 2-3 hours, we'll be evaluating your organization's capabilities across [Digital Sovereignty / Security] domains using a proven 5-level maturity framework."

"This assessment is designed to be honest and constructive—not punitive. Most organizations score between levels 2-3 initially, and that's perfectly normal. The goal is to establish a baseline and identify priority areas for improvement."

"I'll be asking questions about your current capabilities and asking for evidence of implementation. Please be candid—overestimating maturity only hurts your own planning. If you're unsure about an answer, we can flag it for follow-up."

Question-by-Question Guidance

How to Score Each Question

Each question has multiple-choice answers corresponding to maturity levels. Guide participants through this process:

1. **Read the question aloud** - Ensure everyone understands what's being asked
2. **Review all options** - Read through all maturity levels before deciding
3. **Ask for evidence** - "Can you show me documentation/tools/policies that demonstrate this?"
4. **Probe deeper** - "Walk me through how this actually works in practice"
5. **Watch for inflation** - Organizations often overestimate; look for concrete proof
6. **Seek consensus** - If participants disagree, facilitate discussion to reach agreement
7. **Document notes** - Use the notes field to capture important context

Evidence-Based Assessment

Always ask for evidence to support maturity claims. Here are examples of acceptable evidence:

Level	Acceptable Evidence Examples
Level 1	Verbal confirmation, acknowledgment of gaps, plans to implement
Level 2	Draft policies, project plans, pilot implementations, partial rollouts
Level 3	Approved policies, documented standards, widespread implementation, training records
Level 4	Metrics dashboards, KPI reports, audit logs, automated compliance reporting
Level 5	Continuous improvement programs, innovation initiatives, industry leadership, published case studies

Maintaining Momentum

Keep the assessment moving while ensuring thoroughness:

- **Set time limits** - Allocate ~2-3 minutes per question; use a visible timer
- **Park discussions** - "That's an important topic; let's capture it for the roadmap discussion and continue"
- **Batch related questions** - "These next 3 questions are all about encryption; let's discuss them together"
- **Take strategic breaks** - Break between domains (5 min every 45 min)
- **Show progress** - "We're through 3 of 7 domains—great progress!"

4. Domain Deep-Dives

This section provides detailed guidance for each Digital Sovereignty domain. Each domain contains 8 questions organized into three tiers:

- **Foundation Tier (Questions 1-3):** Basic capabilities and policies
- **Strategic Tier (Questions 4-6):** Advanced implementation and control
- **Advanced Tier (Questions 7-8):** Optimization and continuous improvement

Understanding Points

Each question is assigned points (1-8) reflecting its importance within the domain. Higher point values indicate more critical capabilities for achieving sovereignty. The assessment automatically calculates domain scores based on selected maturity levels and point values.

Domain 1: Data Sovereignty

Domain Overview

This domain assesses an organization's ultimate control over its data, independent of external jurisdictions or political influences. It goes beyond basic data residency by focusing on legal control, access, and encryption management. Maturity here confirms that data location is actively governed by the organization's legal and business requirements, rather than dictated solely by a cloud provider or foreign law.

Key Concepts to Explain

- **Data Residency vs. Data Sovereignty:** Residency = where data physically resides; Sovereignty = legal control and ability to resist foreign access demands
- **Jurisdictional Control:** Ensuring data and access are governed by domestic law, not foreign legal frameworks like the CLOUD Act
- **Encryption Key Management:** The entity controlling encryption keys ultimately controls access to data, regardless of where it's stored
- **Data-in-Use Protection:** Protecting data during processing, not just at rest and in transit

Common Customer Misconceptions

Watch Out For

- **"We use a local cloud region, so we have data sovereignty"**
 - Physical location alone doesn't guarantee sovereignty if the provider is subject to foreign law
- **"Encryption protects our sovereignty"** - Not if the cloud provider controls the keys or can be compelled to decrypt
- **"GDPR compliance means we have data sovereignty"** - Compliance is necessary but not sufficient for true sovereignty
- **"We don't have sensitive data"** - Most organizations underestimate the sensitivity and value of their data assets

Question 1: Data Residency & Location (1 point - Foundation)

What this measures: Whether the organization explicitly controls where data is stored based on legal requirements

Key questions to ask:

- "Do you have a written data residency policy?"
- "Can you show me which cloud regions your data is stored in?"
- "How do you prevent data from being accidentally stored outside approved regions?"
- "What happens if a cloud provider wants to move your data for operational reasons?"

Evidence to request: Data residency policy document, cloud provider contracts specifying regions, configuration screenshots showing geo-restrictions

Red flags: "We think it's in [region]", "The cloud provider handles that", "We haven't checked recently"

Question 2: Data Protection & Privacy (2 points - Foundation)

What this measures: Compliance with data protection regulations and implementation of privacy controls

Key questions to ask:

- "Which data protection regulations apply to you? (GDPR, CCPA, PIPL, etc.)"
- "How do you handle data subject rights requests (access, deletion, portability)?"
- "Do you have a Data Protection Officer or equivalent role?"
- "How are cross-border data transfers authorized and tracked?"

Question 5: Cryptographic Key Management Control (6 points - Strategic)

What this measures: Whether the organization exclusively controls encryption keys, independent of cloud providers

Key questions to ask:

- "Who generates and stores your encryption keys?"
- "Can your cloud provider access your encryption keys?"
- "Do you use HSMs (Hardware Security Modules)? Where are they located?"
- "How frequently do you rotate encryption keys?"

Note: This is a 6-point question because key control is fundamental to data sovereignty. Organizations often struggle here.

Domain 2: Technical Sovereignty

Key Focus Areas: Technology stack ownership, vendor lock-in mitigation, standardized frameworks, interoperability, hardware provenance, self-hosted runtimes, IP control, future-proofing

Common Discussion Topics: Open source adoption, Kubernetes and containerization, multi-cloud strategies, escrow agreements, supply chain security

Domain 3: Operational Sovereignty

Key Focus Areas: Process documentation, managed service dependencies, IAM, internal skills, disaster recovery, supply chain vetting, incident response, operational autonomy

Common Discussion Topics: Break-glass procedures, in-house vs. outsourced operations, business continuity planning, geopolitical isolation scenarios

Domain 4: Assurance Sovereignty

Key Focus Areas: Audit rights, sovereign SIEM, compliance verification, transparency requirements, sovereign certifications, continuous monitoring, security testing, vulnerability management

Common Discussion Topics: Right to audit clauses, SOC 2 Type II, penetration testing, third-party attestations, domestic vs. foreign auditors

Domain 5: Open Source

Key Focus Areas: Open source strategy, community participation, license compliance, vulnerability management, sovereign distributions, contribution policies, internal expertise, project governance

Common Discussion Topics: Red Hat Enterprise Linux, Kubernetes, Apache projects, InnerSource, security scanning

Domain 6: Executive Oversight

Key Focus Areas: Board awareness, dedicated governance, budget allocation, sovereignty policies, risk management, accountability, strategic planning, regulatory engagement

Common Discussion Topics: Board reporting, sovereignty champions, dedicated budgets, KPIs and metrics

Domain 7: Managed Services

Key Focus Areas: Vendor selection criteria, contractual controls, geographic restrictions, data access limitations, performance monitoring, transition planning, alternatives evaluation, insourcing capabilities

Common Discussion Topics: Domestic vs. foreign MSPs, data center locations, exit strategies

5. Post-Assessment Activities

Results Interpretation

After completing the assessment, guide the customer through understanding their results.

Understanding the Spider Chart

The spider/radar chart provides a visual representation of maturity across all domains:

- **Balanced shape:** Consistent maturity across domains
- **Spikes and valleys:** Strength in some areas, gaps in others
- **Small overall size:** Early-stage maturity (common and expected)
- **Industry comparison:** Compare against weighted targets for their LOB



Typical Results

Most organizations on their first assessment score:

- **Overall average:** 30-45% (Managed to Defined levels)
- **Strong domains:** Often Executive Oversight, basic Data Protection
- **Weak domains:** Often Cryptographic Key Management, Workload Protection, Operational Autonomy

Reassure customers that these results are normal starting points, not failures.

Gap Analysis and Prioritization

Priority	Criteria	Example
Critical (0-3 months)	Regulatory requirement, high industry weighting, Level 1 on high-point questions	Implementing HSM-based key management for healthcare patient data
High (3-6 months)	Significant sovereignty risk, medium weighting, Level 2 on strategic questions	Establishing sovereign audit rights with cloud providers
Medium (6-12 months)	Important capability, standard weighting, Level 2-3 on foundation questions	Implementing data classification and discovery tools
Low (12+ months)	Optimization, already at Level 3+, advanced questions	Establishing open source contribution programs

Next Steps and Follow-up



Recommended Follow-up Schedule

- **Week 1:** Send detailed results summary and initial recommendations
- **Week 2-3:** Schedule roadmap planning workshop (2 hours)
- **Month 2:** Check-in on quick wins and foundation initiatives
- **Quarter 2:** Progress review and assessment update for changed answers
- **Annual:** Full reassessment to measure improvement

6. Facilitator Tips & Best Practices

Do's

- **Do prepare thoroughly:** Review the customer's industry, known technologies, and recent news
- **Do set expectations:** Explain that honest assessment is better than inflated scores
- **Do ask for evidence:** "Can you show me?" is your most important question
- **Do take detailed notes:** Capture context, concerns, and follow-up items
- **Do remain neutral:** You're a facilitator, not a judge; help them self-assess accurately
- **Do celebrate progress:** Acknowledge what they're doing well

Don'ts

- **Don't sell during assessment:** Stay consultative; sales conversations come after results review
- **Don't accept vague answers:** "We're planning to" or "We're working on it" usually means Level 1
- **Don't inflate scores:** It only hurts their planning and your credibility
- **Don't argue:** If they insist on a rating despite lack of evidence, document the discrepancy
- **Don't skip breaks:** Assessment fatigue leads to poor decisions

Remote Facilitation Tips

When conducting assessments remotely:

- Use video to read body language and maintain engagement
- Share your screen showing the assessment tool for transparency
- Use collaboration tools (digital whiteboard) for visual discussions

- Record the session (with permission) for reference
- Check in verbally more frequently: "Is everyone still with me?"
- Use chat for parking lot items and questions

7. Appendix

Glossary of Key Terms

Term	Definition
BYOK	Bring Your Own Key - Customer-generated encryption keys imported to cloud provider
CLOUD Act	US law allowing government access to data held by US companies regardless of location
Confidential Computing	Protection of data during processing using hardware-based secure enclaves
Data Residency	Physical location where data is stored
Data Sovereignty	Legal and technical control over data, including ability to resist foreign access demands
DLP	Data Loss Prevention - Tools to monitor and prevent unauthorized data transfers
EKM	External Key Management - Encryption keys managed outside cloud provider infrastructure
HSM	Hardware Security Module - Dedicated cryptographic processor for key management
PAM	Privileged Access Management - System for controlling and monitoring administrative access
TEE	Trusted Execution Environment - Secure area of processor for sensitive operations
Zero Trust	Security model assuming no implicit trust, requiring verification for all access

Reference Materials

- **CMMI Framework:** <https://cmmiinstitute.com/>
- **GDPR:** General Data Protection Regulation (EU)
- **NIS2 Directive:** Network and Information Security Directive (EU)
- **DORA:** Digital Operational Resilience Act (EU)
- **FedRAMP:** Federal Risk and Authorization Management Program (US)

Quick Reference: Maturity Level Indicators

Level	Key Indicators	Common Language
1	No policy, ad-hoc, reactive, "we're planning to"	"We know we need to do this"
2	Draft policies, pilots, project plans, some implementation	"We're working on it"
3	Approved policies, widespread deployment, documented standards	"We have this in place"
4	Metrics, dashboards, KPIs, regular reporting, measured outcomes	"We measure and optimize this"
5	Continuous improvement, innovation, industry leadership	"We're leading the industry"